

TD1 : Audit sur la robustesse des identifiants de connexion des différents partenaires

Table des matières

1) Problématique.....	1
2) Prérequis	1
3) Etape 1 : Configuration de Windows 10.....	2
4) Etape 2 : Configuration de Kali Linux.....	4
3) Etape 3 : John the Ripper	5
4) Etape 4 : Table arc en ciel avec Ophcrack	5
5) Conclusion.....	6

1) Problématique

Nous cherchons à utiliser la machine virtuelle Kali Linux pour réaliser des tests d'usurpation des éléments de connexion qui serviront à s'assurer que la sensibilisation des utilisateurs a été efficace. Pour faire cela nous allons donc installer l'image de Kali Linux et l'image de Windows 10 sur notre ordinateur et effectuer plusieurs étapes qui permettront de configurer les machines virtuelles et d'effectuer les tests.

2) Prérequis

Pour effectuer les étapes il faut installer les fichiers .iso de Windows 10 et de Kali Linux.

Pour cela on peut utiliser le site <https://os.click>

Lorsque c'est fait on doit utiliser le logiciel de machines virtuelles Oracle VirtualBox.

On ouvre chaque iso dans la machine séparément et on boot chacune.

Lorsque les deux sont installés et prêt à l'utilisation, on peut commencer les configurations des deux environnements.

3) Etape 1 : Configuration de Windows 10

Pour configurer notre environnement pour la demande, nous allons créer 3 comptes qui vont être placés dans le groupe administrateur. Pour créer les comptes nous allons utiliser CMD de cette façon :

net user ENEDIS judo63 /add

puis **net user MSA aurillac15 /add,**

et enfin **net user CLIC Alexandre.**-- /add**

Et lorsque c'est fait nous devons les ajouter au groupe administrateur avec cette commande :

net localgroup Administrateurs NomDuCompte /add

Lorsque cela est fait il va falloir installer le logiciel fgdump grâce au lien suivant :

<http://lienmini.fr/882-03>

Ensuite on l'installe avec ce lien :

fgdump 2.1.0 no source
(ZIP format, MD5Sum:a6057c3321471b8f4149e4e30200f69b) (05/07/2008)

(il va falloir au préalable désactiver la protection de chrome et de windows) :



Aucune **protection** (non recommandé)

Ce mode ne vous protège pas contre les téléchargements, les extensions et les sites Web dangereux. Vos paramètres de navigation sécurisée dans les autres produits Google ne seront pas affectés.

Protection en temps réel

Cette fonction permet d'identifier et d'empêcher l'installation ou l'exécution des programmes malveillants sur votre PC. Vous pouvez la désactiver temporairement, mais nous la réactiverons automatiquement après un certain temps.

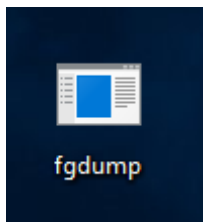


Désactivé

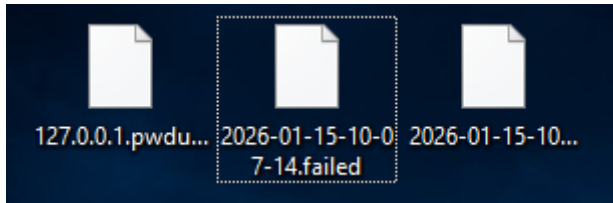
Pour pouvoir ouvrir le zip nous allons aussi installer WinRAR sur www.win-rar.com



Lorsque WinRAR est installé on extrait le dossier RAR et on lance fgdump.exe :



Cela va ouvrir un terminal et faire apparaitre 3 fichiers :



Maintenant nous allons installer notepad++ sur www.notepad-plus-plus.org

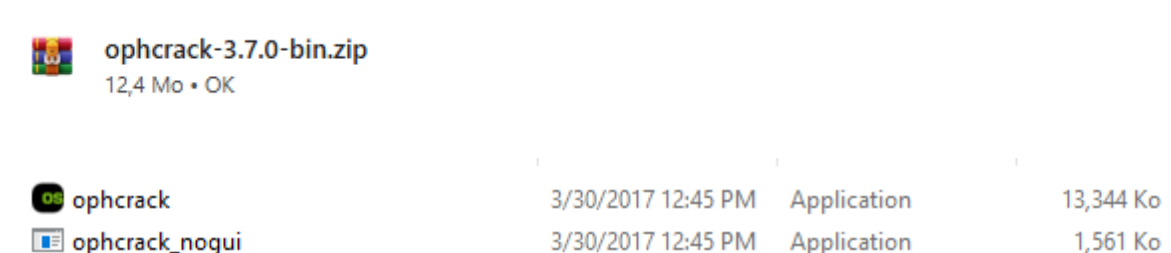
Ensuite lorsque c'est installé nous allons ouvrir le fichier 127.0.0.1.pwdump (si il est vide il faut relancer le logiciel fgdump en administrateur). Voici le résultat :

```
Administrateur:500:NO PASSWORD*****:2ED956ED88DE1B0137E1464D462D1EF4:::
CLIC:1003:NO PASSWORD*****:BFD48145D759530F96BFC125A40D12C3:::
DefaultAccount:503:NO PASSWORD*****:NO PASSWORD*****:
ENEDIS:1001:NO PASSWORD*****:4BC7C70459A563005471F6922810249C:::
Ewan:1000:NO PASSWORD*****:2ED956ED88DE1B0137E1464D462D1EF4:::
Invité:501:NO PASSWORD*****:NO PASSWORD*****:
MSA:1002:NO PASSWORD*****:93B1FAF08A26ED40415F2CDDD17DE771:::
```

Nous allons le modifier pour ne garder que les 3 comptes précédents :

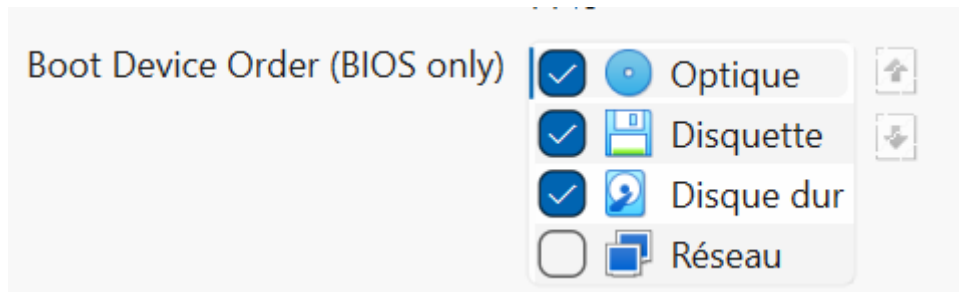
```
CLIC:1003:NO PASSWORD*****:BFD48145D759530F96BFC125A40D12C3:::
ENEDIS:1001:NO PASSWORD*****:4BC7C70459A563005471F6922810249C:::
MSA:1002:NO PASSWORD*****:93B1FAF08A26ED40415F2CDDD17DE771:::
```

Pour finir notre configuration nous allons installer ophcrack sur SourceForge et décompresser le ZIP :



4) Etape 2 : Configuration de Kali Linux

Pour pouvoir faire le lien entre la VM Windows et Kali Linux il faut faire un clic droit sur la VM de Kali Linux, ensuite il faut mettre l'optique tout en haut dans la section Système :



Puis il faut aller dans la section stockage, cliquer sur ce bouton :



Ajouter le windows.vdi :



Et cocher le Solid State Drive à droite :



Kali Linux devrait proposer de choisir la langue du clavier lorsque de l'installation, mais si le clavier est en anglais alors il faudra utiliser la commande **setxkbmap fr**.

Maintenant nous allons voir quelle partition de disque appartient à Windows avec la commande **fdisk -l** :

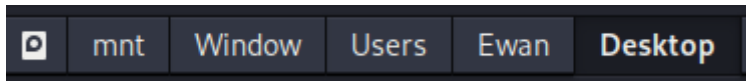
Device	Boot	Start	End	Sectors	Size	Id	Type
/dev/sdb1	*	2048	104855551	104853504	50G	7	HPFS/NTFS/exFAT

Ici il s'agit de sdb1.

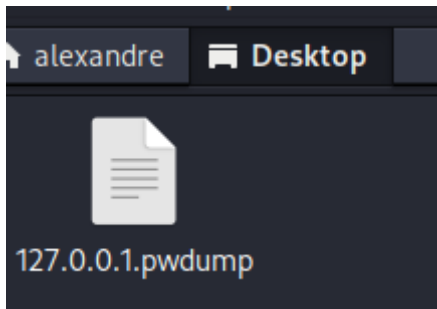
Lorsque c'est fait nous allons créer un dossier où nous allons monter le dossier windows avec **sudo mkdir /mnt/windows**

Ensuite on monte dans le dossier avec **sudo mount /dev/sdb1 /mnt/windows**

Lorsque c'est fait nous allons accéder au fichier de fgdump dans notre bureau en suivant ce chemin grâce à l'explorateur de fichier :



Ensuite on copie le fichier et on le colle dans le bureau de Linux (pas Windows) :

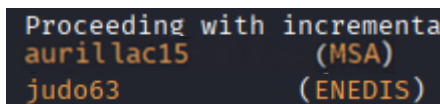


3) Etape 3 : John the Ripper

Maintenant que tout cela est fait nous allons tester l'attaque par défaut avec la commande suivante : `john --format=NT ~/Desktop/127.0.0.1.pwdump`

`John --format=NT ~/Desktop/127.0.0.1.pwdump.`

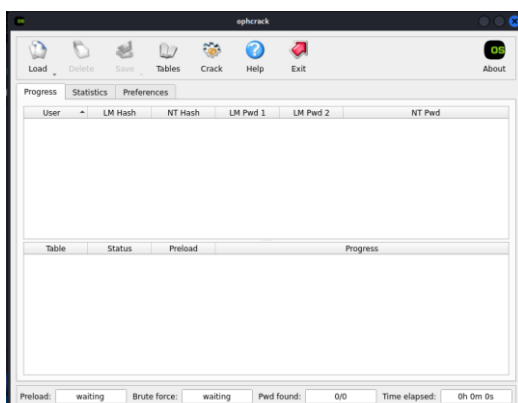
Résultat :



J'ai pu trouver facilement ces deux identifiants car ils ne sont pas assez long, mais celui de CLIC que j'ai pu choisir était complexe et donc le logiciel n'a pas pu le trouver.

4) Etape 4 : Table arc en ciel avec Ophcrack

Désormais nous allons essayer l'outil Ophcrack avec **sudo ophcrack** :



IMPORTANT : La suite de la partie 4 n'est pas faite car c'est à partir de là où j'ai eu mon problème technique avec mon ordinateur pendant plus d'un mois et demi, si le TP est noté veuillez en prendre compte s'il vous plaît.

5) Conclusion

En conclusion, j'ai appris durant ce TP à comprendre la façon dont on peut utiliser la machine virtuelle Kali Linux pour effectuer des tests qui permettent de s'assurer de l'efficacité de la sensibilisation des utilisateurs.